Privacy Labels for AI — Student Lab Sheet

Overview
In this lab, you will get into smaller groups and design a privacy label for a fictional AI product and get another group to review it.

Group size	3 – 4 students
Your product type	Generative AI or Agentic AI
You will need	Your scenario card (from your TA)

By the end of this lab, you should be able to:

- Explain how the privacy risks of generative and agentic AI differ from those of ordinary apps.
- Pick out the practices in an AI product that users most need to know before they decide to use it.
- Design a security and privacy label that communicates security and privacy practices in plain language.
- Evaluate a label with a quick comprehension test, and critique what labels can and cannot do as an intervention.

Background

Privacy labels
A privacy label is a short summary in a standard format that shows how an app or device handles your personal data, placed where you decide whether to use it. It works like the Nutrition Facts panel on food: you scan a few fixed headings instead of reading the full privacy policy, and you can compare two products side by side. Researchers at Carnegie Mellon proposed a "privacy nutrition label" in 2009. Apple has required privacy labels on App Store listings since December 2020, Google Play has required a Data safety section since July 2022, and researchers have proposed security and privacy labels for smart (IoT) devices.

Why do they exist?
Privacy policies are long, and almost nobody reads them. McDonald and Cranor found the median policy ran to 2,514 words, about 10 minutes to read. They estimated that reading every policy a typical American comes across in a year would take about 76 workdays (source). A label puts the few facts most people need where they will actually see them.

Source: *https://www.benton.org/headlines/reading-privacy-policies-you-encounter-year-would-take-76-work-days*

What one looks like.

App Privacy

The developer, Apple, indicated that the app's privacy practices may include handling of data as described below. For more information, see the developer's privacy policy.

Learn how the developer lets you manage your privacy choices.

To help you better understand the developer's responses, see Privacy Definitions and Examples.

Privacy practices may vary based on, for example, the features you use or your age. Learn More

Data Linked to You

The following data, which may be collected and linked to your identity, may be used for the following purposes:

App Functionality

Location
Coarse Location

Identifiers
Device ID

Data Not Linked to You

The following data, which may be collected but is not linked to your identity, may be used for the following purposes:

Analytics

Search History
Search History

Identifiers
User ID

Usage Data
Product Interaction

Diagnostics
Performance Data

App Functionality

Location
Precise Location

Diagnostics
Performance Data

Check labels on Your Phones (2 minutes). Open any app's page in your phone's app store. On an iPhone, scroll down to **App Privacy**. On Android, tap **Data safety**. Note what the app collects and whether anything is used to track you.

Most existing labels answer one main question: **what data does this collect, and what happens to it?** They list data types, whether data is linked to you, and whether it is shared or used to track you. Research shows they help people compare products, but people often skim them, developers sometimes fill them in inaccurately, and fixed categories can miss what matters most.

Words you will see on labels

Term	Plain meaning
Personal data	Any information about you, such as your name, your location or what you type
Linked to you	Connected to your identity, for example through your account
Tracking	Following you across other companies' apps and websites, usually for ads
Third party	Any company other than the one that makes the product
Retention	How long data is kept before it is deleted
Default	What happens if you never change a setting
Opt out / opt in	Opt out: it's on until you turn it off. Opt in: it's off until you turn it on

Why AI is different

For AI products, users often care about questions an app label was never designed to answer:

- Is what I type, upload or say used to train the AI?
- How long is it kept, and can a person at the company read it?
- Does it remember things about me, and can I see or delete them?
- What does it work out about me beyond what I told it?
- For agents: what can it reach, what can it do without asking me, and who else is affected?

Generative AI vs Agentic AI

	Generative AI	Agentic AI
What it does	Responds to you: produces text, images or code	Acts for you: pursues a goal over several steps, using tools
What it touches	What you give it	What it can reach: your accounts, files, money, websites, other people
Who decides the next step	You	Often the agent
The key privacy question	What happens to what I gave it?	What can it reach, what can it do, and who else is involved?

Real products sit on a spectrum rather than in two boxes. A chatbot that searches the web or remembers past chats is already part of the way towards being an agent. Part of your job today is deciding which behaviors your label needs to describe.

What you will produce

Your group hands in three things by the end of the lab.

- **A privacy label** for your product.
- **A design rationale** of about 150 words: who your user is, what decision the label helps them make, what you left out and why, and one change you would make after testing.
- **Feedback**: You should at least get feedback from another group about your label.

You will also test another group's label, so expect to spend part of the lab as a user rather than a designer.

Lab steps
The lab runs in five steps, and design stops at **1230** sharp so there is time to test.

Step	What you do
1. Analyze your scenario	Read your scenario card and complete Worksheet A.
2. Design your label	Build the primary and detailed layers.
3. Swap and test	Test your partner group's label, they test yours, then compare results.
4. Debrief	Class discussion and exit ticket.

Step 1: Analyze your scenario (10 min)

Your TA gives your group a scenario card for a fictional AI product. Keep it to your group: the testers must not see it.

- On your own, read the card and mark each practice that a typical user would find surprising, or that would change whether they use the product.
- As a group, agree on the 5 - 6 practices that must go on the primary layer.

Step 2: Design your label (50 min)
Split roles: **designer** (layout and visuals), **writer** (plain-language wording), **checker** (checks every claim against the card and the requirements checklist), **timekeeper**.

- Spend the first 5 minutes sketching at least two different layouts before you commit to one.
- Build the primary layer first, then the detailed layer if you want.
- Run the requirements checklist. Keep your design clean and ready for the other group.

Step 3: Swap and test (15 min)
Your group is paired with a group that worked on the *other* AI type.

What happens
Hand your **label** to another group. Your TA will give you questions for testing.

As a tester, answer only from the label in front of you. Don't guess from what you know about real products. "Can't tell from the label" is a valid answer and useful data for the designers.

Step 4: Debrief (10 min)
Your TA leads a class discussion comparing generative and agentic labels.

One thing a security and privacy label for AI cannot tell a user is _____, because _____.

Worksheet A: Analyze your scenario

Use this worksheet to decide what your label must say before you design how it looks.

Product name: _____

Type: Generative AI / Agentic AI (circle one)

1. Who is your typical user, and what decision will the label help them make?

2. List the practices on your card that matter most to that user.

Security or Practice from your card	Would a typical user be surprised? (Y/N)	Would it change their decision? (Y/N)	Plain-language wording for the label

3. Answer the questions for your product type.

Generative AI system:

- What happens to what the user types, says or uploads (training, how long it is kept, who can see it)?
- Does the product do anything automatically, without being asked?

Agentic AI System:

- What can the agent reach (accounts, files, money, devices)?
- What can it do without asking first, and what does it ask about?
- How can the user see what it did, and undo or stop it?
- Who else is affected who never signed up?

4. Is there anything the product does well that the label should show?

Label design requirements
Your label must meet every item on this checklist; the checker ticks them off before 0:45.

Checklist

- ☐ **Primary layer.** The primary layer fits on one phone screen or index card, holds at most 6 items, and can be read in about 10 seconds.

- ☐ **Defaults and controls.** It says what is on by default and what the user can change (for example, "On by default — you can turn this off in Settings").
- ☐ **Plain language.** No wording copied from the card, and no jargon unless you explain it.
- ☐ **Accurate.** Every claim matches your scenario card. Don't invent practices; if something is unclear, leave it out.
- ☐ **Visual meaning.** At least one visual element (icons, color, layout) carries meaning, with a key, and still works if printed in black and white.

- ☐ **Generative AI System:** it covers what happens to the user's inputs (training, retention, human review) and anything the product does automatically.

  Or

- ☐ **Agentic AI System:** it covers access (what the agent can reach), autonomy (what it does without asking), visibility (how to see and undo its actions) and other people affected.

Formats you can borrow

Format	Good for	Watch out for
Nutrition-label table	Comparing products line by line	Can look dense on a phone
Icons with short phrases (app-store style)	Fast scanning	Icons people don't recognize
Traffic lights	Showing level of risk	Implies a judgment you must justify
"Before you connect" checklist	Agents that ask for account access	Can read like terms and conditions
Data journey or timeline	Showing what happens to an input over time	Hard to fit on the primary layer

Worksheet B: Swap and test

This worksheet captures how well your label worked for real readers.

Part 1: Testing your partner group's label

Your TA gives you a question sheet with 7 questions about your partner's product.

- Circle Yes, No or Can't tell, and add a few words.
- Return the question sheet to the designers for discussion.

Further reading

These are optional, but the first two will help you most before the lab.

- Kelley, Bresee, Cranor and Reeder (2009). A "Nutrition Label" for Privacy. SOUPS 2009. The original privacy nutrition label and how it was tested.
- Emami-Naeini, Agarwal, Cranor and Hibshi (2020). Ask the Experts: What Should Be on an IoT Privacy and Security Label? IEEE S&P 2020. Where the primary and secondary layer idea comes from.
- Understanding Challenges for Developers to Create Accurate Privacy Nutrition Labels (CHI 2022). Why real labels are often wrong.
- A Solution toward Transparent and Practical AI Regulation: Privacy Nutrition Labels for Open-source Generative AI-based Applications (arXiv, 2024). A proposed label format for generative AI apps.
- Tran, Lu, Fu et al. (2025). Understanding Privacy Norms Around LLM-Based Chatbots: A Contextual Integrity Perspective. AIES 2025. What chatbot users expect to happen to their conversations.
- Mitchell et al. (2019). Model Cards for Model Reporting. A developer-facing way to document AI models, useful as a contrast to user-facing labels.